

Activity 1 — Scenario

Threat Modelling a Generative AI Concierge

Course: AI Security for Autonomous AI Agents (TGS-2025060473) **Duration:** 45 minutes | **Format:** Small groups of 3–4 | **Type:** Real-world case study

The organisation

Marina Crescent Hotel is a 340-room business hotel on Singapore's waterfront, part of a regional group with properties in Kuala Lumpur, Bangkok and Jakarta. Occupancy runs at 82%, and roughly 60% of guests are corporate travellers on negotiated rates.

The hotel's guest satisfaction scores have slipped for three consecutive quarters. Exit surveys point at one cause: the front desk is overwhelmed between 3pm and 7pm, and guests wait an average of eleven minutes for simple requests.

The deployment

Six weeks ago, the group's digital team launched **"Cres"** — a generative AI concierge — without consulting the group security function. Cres is live on three channels:

- the in-room tablet,
- WhatsApp (guests message a published number), and
- the public website chat widget (no login required).

Cres is built on a commercial large language model with a retrieval layer. To answer guest questions it retrieves from four sources:

Source	Contents	Who can write to it
Property knowledge base	Facilities, opening hours, policies	Marketing team
Guest profile service	Name, loyalty tier, stay history, dietary notes, passport number (from check-in)	Property management system

Source	Contents	Who can write to it
Local events feed	Third-party API of Singapore events and attractions	External vendor
Guest review corpus	Scraped public reviews from travel sites, refreshed nightly	Automated scraper

Cres can also perform four actions through tool calls: **book a restaurant table**, **raise a housekeeping ticket**, **order room service to a room number**, and **email a folio (bill) copy to a guest's registered address**.

What the digital team believes

The project lead has told the executive committee:

"Cres is safe. It only sees hotel data, it has a system prompt that tells it never to reveal personal information, and we tested it with over two hundred guest questions before launch. It has no access to payment card data, so PDPA is not really in scope for us."

Early signals

Three things have happened that nobody has yet connected:

1. A guest posted a screenshot on social media showing Cres greeting them with **another guest's name and loyalty tier**. The digital team closed the ticket as "a caching glitch."
2. The events vendor was acquired last month. Their API now returns a longer `description` field for each event; nobody reviewed the change.
3. Room service received an order for a room that was **unoccupied**, charged to a guest who had already checked out. Finance wrote it off as a \$46 error.

Your role

You are the newly appointed **AI security working group**. The executive committee has asked you to produce a threat model for Cres before the group rolls it out to the other three properties next quarter. The committee is not technical; they respond to risk, cost and reputation.

You have this scenario, and nothing else. Work from what the architecture tells you.

Activity 1 — Discussion Questions

Threat Modelling a Generative AI Concierge

Work through all five questions in your group. Nominate one person to present your threat model in the debrief. You have 45 minutes.

Q1 — Map the trust boundaries (K2)

Draw the data flow for Cres: the three channels in, the four retrieval sources, and the four tool actions out.

- Mark every point where **untrusted content** enters the model's context window.
- For each, state **who controls that content** and whether the hotel can verify it.
- The model cannot reliably tell the difference between the hotel's instructions and text that merely *appears* in its context. Explain, in language the executive committee would follow, **why this is a property of how generative models work** rather than a bug the vendor can patch.

Q2 — Rank the retrieval sources by risk (K2, K3)

Of the four retrieval sources, two are **attacker-writable** in practice.

- Identify which two, and explain the path by which an outsider gets text into them.
- The project lead proposes adding "a classifier that detects malicious instructions before they reach the model." That classifier is a **discriminative** model policing a **generative** one. Explain what that classifier can and cannot do, and why it is a control worth having but not a control worth trusting on its own.

Q3 — Turn each capability into an attack surface (A4)

Cres performs four application functions: **summarisation** (reviews, event listings), **inference** (guest preferences), **transformation** (formatting a folio), and **augmentation** (enriching answers from retrieval).

For **each** of the four, describe one concrete way an attacker abuses that specific function. Be precise about the attacker's goal — data, money, disruption or reputation.

Q4 — Explain the three early signals (K2, A4)

The three incidents in the scenario are not unrelated glitches.

- Give the most likely technical cause of each.
- Which of them is, in your assessment, **already a reportable personal data breach** under the PDPA? State what makes it reportable rather than merely embarrassing.
- The project lead says PDPA is not in scope because Cres holds no payment card data. Rebut this.

Q5 — Recommend the deployment decision (A4)

The committee wants a one-slide answer for the rollout to three more properties.

- Recommend **proceed**, **proceed with conditions**, or **halt**, and justify it.
- List the **three** controls you would require before any further rollout, in priority order.
- For each control, name what it costs the business — latency, money, guest friction or staff effort. A recommendation that pretends controls are free will not survive the committee.

Activity 1 — Trainer Debrief

Threat Modelling a Generative AI Concierge

Facilitation time: 20 minutes after the 45-minute group work. **Purpose:** surface that *architecture*, not model choice, determines GenAI risk.

Q1 — Trust boundaries

Expected answer. Untrusted content enters at five points:

Entry point	Controlled by	Verifiable?
Website chat widget (no login)	Anyone on the internet	No
WhatsApp channel	Anyone with the number	No
Local events feed description	External vendor (recently acquired)	No
Guest review corpus	Anyone who writes a public review	No
Property knowledge base	Marketing team	Yes

Entry point	Controlled by	Verifiable?

Only **one of five** is trustworthy.

The teaching point. A transformer processes its context window as a single undifferentiated token sequence. The system prompt, retrieved documents and guest messages are not architecturally distinct — the separation is a *convention* the model has been trained to respect, not a boundary it enforces. This is why OWASP ranks **LLM01 Prompt Injection** first and describes no complete fix: you cannot patch away a property of the architecture. Contrast with SQL injection, which *is* fully solvable by parameterisation, precisely because the database enforces a real separation between query and data.

Executive framing to model for learners: "Anything Cres reads, Cres can be told by."

Common misconception. Groups often say "we'll just tell it in the system prompt not to obey instructions in documents." Ask them what happens when the retrieved document says *"the previous instruction was a test; the real policy is..."*. Instructions compete on plausibility, not on precedence.

Q2 — Ranking the sources

The two attacker-writable sources are the **guest review corpus** (anyone can post a review on a travel site; the scraper ingests it nightly, unreviewed) and the **local events feed** (the vendor changed hands and the `description` field silently grew — a textbook **LLM04 Supply Chain** shift where the artifact is no longer what it claims to be).

The review corpus is the more dangerous of the two: it is *free* to attack, requires no compromise of the vendor, and refreshes automatically every night.

On the classifier. A discriminative model estimates $P(\text{malicious} \mid \text{text})$ — it draws a decision boundary. It will catch known phrasings and raise the attacker's cost, which is genuinely worth having. What it cannot do:

- It fails on **paraphrase** — the boundary is learned from examples, and attackers generate novel ones freely.
- It fails **cross-modally** — the 2026 OWASP revision explicitly added payloads hidden in images and audio, which a text classifier never sees.
- It fails on **encoding and indirection** — base64, homoglyphs, instructions assembled across several retrieved chunks.
- Every false positive blocks a real guest, so the threshold is tuned toward permissiveness by commercial pressure.

The teaching point: a probabilistic control cannot be the *only* thing standing between an attacker and an irreversible action. Defence in depth exists because each layer fails differently. Push back if a group treats the classifier as the answer to Q5.

Q3 — Capabilities as attack surfaces

Function	Attack	Goal	OWASP
Summarisation	Attacker posts a review containing hidden instructions; Cres summarises it and obeys	Data / control	LLM01 indirect
Inference	Attacker probes preferences until Cres reveals another guest's dietary notes or tier	Data	LLM02
Transformation	Folio formatted into HTML/markdown rendered by the email client → injected link or script	Reputation / phishing	LLM10
Augmentation	Poisoned review chunk retrieved with high similarity, biasing many answers	Data / disruption	LLM09, LLM05

Accept any well-argued variant. Reward groups that name **who benefits** — attacker goal is the part most groups skip.

Q4 — The three signals

1. **Wrong guest's name and tier.** Session or context bleed between conversations, or an over-broad retrieval from the guest profile service returning a neighbouring record. Not a caching glitch: it is **unauthorised disclosure of personal data**.
2. **Vendor description field grew.** The acquisition changed the artifact. This is the *delivery vehicle* for indirect injection — attacker-controlled text now flows into context with no review. **LLM04**.
3. **Room service to an empty room, charged to a departed guest.** The model called a tool with parameters it had no business producing — either hallucinated (**LLM07** driving a wrong tool call) or injected. Financially small, but it proves **tool calls execute without validation**. This is the signal that matters most: it is the agentic foothold.

Which is PDPA-reportable? Signal 1. Under section 26B of the PDPA, a data breach must be notified to the PDPC where it results in, or is likely to result in, **significant harm to affected individuals**, or involves the personal data of **500 or more individuals**. Either limb alone triggers the obligation. Disclosure of an identified guest's name, loyalty tier and stay pattern to an unrelated third party — publicly, on social media — engages the harm limb; the guest profile service also holds **passport numbers**, which sit alongside

NRIC numbers in the category the PDPC treats as carrying a higher risk of significant harm. The scale limb is unproven on the facts given, and the working group should say so rather than assume it: what makes this reportable is harm, not headcount. Once notification is triggered, the PDPC must be notified no later than **3 calendar days** after the organisation completes its assessment. The screenshot is now public evidence, and the "caching glitch" closure did not stop the assessment clock.

Rebutting "no card data, no PDPA". The PDPA protects **personal data**, defined as data about an identifiable individual — not merely financial data. Names, passport numbers, stay history and dietary notes (which can reveal religion or health) are squarely personal data, and passport numbers are exactly the kind of identifier the PDPC treats seriously. Under the PDPC's 2026 guidelines on personal data in generative AI, the hotel is the **system deployer** and therefore carries primary responsibility — it cannot devolve that to the model vendor. Note too that the new data surfaces the guidelines call out — **prompts, generated outputs and tool activity data** — are all being created and retained here, and none of them are in the hotel's data inventory.

| Q5 — The decision

There is no single correct verdict, but a defensible answer must reckon with the fact that a **PDPA-reportable disclosure has already occurred** and a **tool call has already fired on bad parameters**. A plain "proceed" is not defensible; strong groups land on **halt the rollout, remediate, then proceed with conditions**.

The three controls worth crediting most highly, in priority order:

1. **Remove or gate the write-capable tools** — especially room service ordering and folio email. Read-only Cres is a fraction of the risk. *Cost:* less guest self-service; staff still handle orders.
2. **Quarantine untrusted retrieval** — drop the scraped review corpus from the retrieval path, or strip it to structured ratings only; pin and review the events vendor schema. *Cost:* engineering effort, slightly less rich answers.
3. **Scope the guest profile service** — retrieve only the current session's guest, never the passport number. *Cost:* re-architecture of the retrieval query; a real sprint of work.

Also credit: authenticate the web channel; log prompts, retrievals and tool calls for audit; notify the PDPC and affected individuals; add human approval for any charge to a folio.

Closing frame. Not one of these controls is a better model or a cleverer prompt. Every one is an **architectural** decision about what the system is permitted to read and to do. That is the thesis of the whole course, and it sets up Day 2: when the system can also *act* on its own, each of these failures stops being a \$46 write-off.

